

شركة دايموند لوساطة التأمين
سياسة إدارة تقنية المعلومات
مايو 2025



Internal

DO NOT COPY

الاسم المسجل: شركة الوثيقة الماسية لوساطة التأمين
المركز الرئيسي: طريق الثمامة، الربيع، الرياض
مسؤول المستند: مدير إدارة الجودة والتطوير

المحتويات	
1	المقدمة
2	الهدف من السياسة
3	تعريف
4	نطاق تطبيق السياسة
5	القطاعات والإدارات ذات العلاقة
6	الكيانات ذات العلاقة
7	قواعد عامة
8	مسؤولية السياسة
9	التعالم والتعليمات ذات العلاقة
10	حفظ السياسة
11	مخالفة السياسة



إدارة الجودة والتطوير Quality & Development Management

المادة (1): يحتوي هذا المستند على المعلومات المتعلقة بشركة الوثيقة الماسية (دايموند) ولا يجوز استخدام أو نسخ هذا المستند أو المعلومات التي يحتوي عليها كاملة أو جزءاً منها أو كشفه إلى الغير ما لم تقدم شركة الوثيقة الماسية (دايموند) موافقتها الكتابية على ذلك. لا يجوز تعديل أو حذف هذا التصريح المقيد في أي حالة من هذا المستند.

المادة (2): في حال وجود اختلاف بين النص العربي والإنجليزي فإن السيادة تكون للنص العربي.



Internal

DO NOT COPY

معلومات السياسة				
سياسة إدارة تقنية المعلومات			عنوان السياسة	
مُحدثة			حالة السياسة	
دليل سياسات وإجراءات تكنولوجيا المعلومات			عنوان السياسة السابقة	
30/10/2018			تاريخ السياسة السابقة	
1ITM0002			رقم المستند	
بعد مُرور سنتين من تاريخ اعتماد السياسة أو عند الضرورة			تاريخ المراجعة القادمة	
قسم خدمات الأعمال			مالك السياسة	
إدارة الجودة والتطوير			إعدت بواسطة	
مسؤولو القطاعات والإدارات الذين راجعوا السياسة ووافقوا عليها				
الإدارة	الوظيفة	الأسم	التاريخ	التوقيع
الإدارة الرقابية	مدير إدارة الإلزام والامتثال	تركي عبد الله العبدلي	29/07/2025	
رئيس مراجعة السياسات	مدير إدارة الجودة والتطوير	شادن سلطان العتيبي	29/07/2025	
اعتماد السياسة				
الإدارة العليا	العضو المنتدب	بدر سعد الشايع	29/07/2025	



إدارة الجودة والتطوير
Quality & Development Management

1. المقدمة:

1.1 تُعد سياسة إدارة تقنية المعلومات جزءاً أساسياً في دعم عمليات الشركة، وتحقيق الكفاءة التشغيلية، وضمان استمرارية الأعمال. ومع تطور التحديات الرقمية والمخاطر التقنية، أصبح من الضروري اعتماد سياسة شاملة لإدارة تقنية المعلومات، تنظم كافة الجوانب المرتبطة بالبنية التحتية، أمن المعلومات، البرمجيات، الأجهزة، الخدمات التقنية، وإدارة الوصول، بما يضمن الحوكمة، الحماية، والامتثال التنظيمي.

2. الهدف من السياسة:

2.1 تثق شركة الوثيقة الماسية لوساطة التأمين (ويشار إليها فيما يلي بـ "دايموند") في أن الهدف من هذه السياسة هو وضع الإطار التنظيمي والإجرائي لإدارة جميع أنشطة تقنية المعلومات داخل الشركة، من خلال تحديد الأدوار، وتوزيع المسؤوليات، وتطبيق الضوابط التقنية والأمنية اللازمة، بما يضمن سلامة الأنظمة، سرية البيانات، تكامل العمليات التقنية، وامتثال الشركة للضوابط الصادرة من الجهات الرقابية والتنظيمية ذات العلاقة.

2.2 كما تهدف السياسة إلى ضمان الاستخدام الأمثل للموارد التقنية وتحقيق أعلى مستويات الكفاءة والجودة والاستمرارية في تقديم الخدمات.

3. تعاريف:

- 3.1 دايموند: شركة الوثيقة الماسية لوساطة التأمين.
- 3.2 الشركة: شركة الوثيقة الماسية لوساطة التأمين، ويشمل هذا التعريف كافة فروعها وكياناتها التابعة.
- 3.3 إدارة تقنية المعلومات: الجهة المسؤولة عن تخطيط وتنفيذ وصيانة وتشغيل البنية التحتية الرقمية للشركة، وضمان أمن وكفاءة الأنظمة التقنية المستخدمة.
- 3.4 البنية التحتية التقنية: تشمل جميع الخوادم، الشبكات، أجهزة الحاسب، معدات الاتصالات، ومرافق مراكز البيانات المستخدمة في تشغيل أنظمة الشركة.
- 3.5 الأصل التقني: أي جهاز أو أداة تقنية تُستخدم ضمن بيئة العمل كجزء من أنظمة المعلومات، وتشمل الحواسيب، الطابعات، أجهزة البصمة، الكاميرات، الخوادم، والموجهات.
- 3.6 سجل الأصول التقنية: قاعدة بيانات مركزية تحتوي على معلومات تفصيلية محدثة عن جميع الأصول التقنية المملوكة للشركة.
- 3.7 البرمجيات الإدارية: جميع البرامج والتطبيقات التقنية المستخدمة لتشغيل وإدارة العمليات الإدارية داخل الشركة، سواء كانت مطورة داخلياً أو مزودة من طرف ثالث.
- 3.8 الامتثال البرمجي: الالتزام باستخدام البرمجيات المرخصة والمعتمدة فقط، وفقاً للأنظمة والتعليمات التقنية والتنظيمية.
- 3.9 نظام التحكم في الوصول (NAC): آلية تقنية تمنع اتصال أي جهاز غير مصرح به بشبكة الشركة.
- 3.10 الأنظمة الأمنية (SIEM / IDS): أنظمة تحليل ومراقبة تسجل وتكشف عن الأنشطة المشبوهة داخل الشبكة التقنية.
- 3.11 النسخ الاحتياطي: عملية نسخ البيانات والمعلومات بشكل دوري للاحتفاظ بنسخة آمنة لاسترجاعها في حال حدوث خلل أو فقد للمعلومات الأصلية.
- 3.12 التشفير (Encryption): آلية حماية تُستخدم لتحويل البيانات إلى صيغة غير مفهومة إلا للأطراف المخولة، باستخدام خوارزميات مثل AES-256.
- 3.13 التحقق الثنائي (FA2): آلية أمنية تتطلب خطوتين لتأكيد هوية المستخدم، مثل كلمة المرور ورمز مؤقت عبر الجوال.
- 3.14 الحادث الأمني: أي خلل أو نشاط غير معتاد يهدد سرية أو سلامة أو توفر المعلومات الإدارية، كالتسريب، التعديل غير المصرح به، أو الاختراق.
- 3.15 DMS: نظام إدارة الوثائق الإلكتروني المعتمد في الشركة لتوثيق وأرشفة الوثائق والمستندات الرسمية.
- 3.16 BCP / DRP: خطتي استمرارية الأعمال واستعادة البيانات المعتمدتين لضمان استمرارية التشغيل في حال الطوارئ أو الكوارث.
- 3.17 مالك المعلومة: الشخص أو الجهة المخولة رسمياً داخل كل إدارة لتصنيف المعلومات وحمايتها والموافقة على مشاركتها.
- 3.18 المستخدم النهائي: أي موظف أو متعاون مُخول باستخدام الأنظمة التقنية وأجهزة الشركة لأداء مهامه المهنية.
- 3.19 المزود التقني الخارجي: أي جهة خارجية تقدم خدمات تقنية للشركة بموجب عقد رسمي.
- 3.20 المعلومات الإدارية: جميع البيانات والمستندات والوثائق الرقمية أو الورقية الناتجة عن عمليات الشركة اليومية.
- 3.21 بيانات شخصية: أي معلومات قابلة للتعرف على هوية فرد معين مثل الاسم، رقم الهوية، رقم الجوال، أو البريد الإلكتروني.
- 3.22 الأنظمة التنظيمية: تشمل الأنظمة الصادرة عن هيئة التأمين، هيئة الاتصالات، سدايا، وهيئة الأمن السيبراني وغيرها من الجهات الرسمية.

4. نطاق تطبيق السياسة :

4.1 تسري هذه السياسة على جميع أنظمة وأصول تقنية المعلومات في الشركة، وتشمل كافة الأجهزة، الخوادم، الشبكات، البرمجيات، أنظمة الاتصالات، البريد الإلكتروني، الحسابات التقنية، المستخدمين المعتمدين. كما تشمل جميع الموظفين ومزودي الخدمات المتعاملين مع البيئة التقنية.

5. القطاعات والإدارات ذات العلاقة:

5.1 إدارة تقنية المعلومات، قسم الأمن السيبراني إدارة الالتزام والامتثال، إدارة الجودة والتطوير، إدارة الموارد البشرية و كافة الإدارات التشغيلية التي تعتمد على الأنظمة التقنية في أداء مهامها.

6. الكيانات ذات العلاقة:

6.1 كافة الكيانات المملوكة بالكامل إلى شركة دايمنود.
6.2 الجهات التنظيمية المشرفة على القطاع (هيئة التأمين، هيئة الأمن السيبراني)

7. قواعد عامة:

7.1 إدارة البنية التحتية والأصول التقنية

7.1.1 يجب شراء جميع الأجهزة والخوادم المستخدمة في تخزين أو معالجة المعلومات الإدارية من موردين معتمدين، وتُطبق مواصفاتها الحد الأدنى من المعايير الفنية المعتمدة في الشركة.

7.1.2 يُلزم بتسجيل كل أصل تقني في سجل الأصول التقنية، ويجب أن يتضمن السجل: الرقم التسلسلي، الفئة، الطراز، الجهة المالكة، المستخدم الفعلي، تاريخ الاستلام، والموقع الحالي.

7.1.3 يجب تحديث سجل الأصول دوريًا كل 6 أشهر على الأقل، ويُلزم بالإبلاغ الفوري عند حدوث نقل، فقدان، أو عطل في أي من الأصول.

7.1.4 يجب محو البيانات بالكامل باستخدام أدوات معتمدة قبل إتلاف الأصول التقنية. يُمنع التخلص من الأصول إلا عبر جهة مرخصة وفقًا للسياسات البيئية والتنظيمية.

7.1.5 يُلزم بتوثيق كل عملية نقل أو حركة للأصول في سجل حركة مستقل، يتضمن بيانات دقيقة حول الجهة المستلمة، حالة الأصل، التاريخ، واسم المسؤول عن التسليم والاستلام.

7.2 الشبكات والاتصالات:

7.2.1 يُمنع ربط أي أجهزة إضافية أو إنشاء شبكات فرعية أو نقاط وصول دون إذن مكتوب من مدير إدارة تقنية المعلومات.

7.2.2 يجب تفعيل أنظمة المراقبة المستمرة للشبكة باستخدام أدوات (NAC / IDS / SIEM) لكشف أي نشاط غير اعتيادي أو جهاز غير مصرح به.

7.2.3 يجب الاحتفاظ بسجلات الوصول الشبكي (Logs) لمدة لا تقل عن 12 شهرًا، مع حماية السجلات من الحذف أو التلاعب.

7.2.4 يُطبق نظام التصنيف الداخلي للشبكات (مثل: شبكة مفتوحة، شبكة مقيدة، شبكة حساسة) مع ضبط صلاحيات كل فئة وفقًا لمبدأ الحد الأدنى من الامتيازات.

7.2.5 يُلزم باستخدام نظام التحكم في الدخول إلى الشبكة (NAC) لحظر أي جهاز لم يتم تسجيله مسبقًا ضمن قائمة الأصول المعتمدة.

7.3 البرمجيات والتطبيقات الإدارية:

7.3.1 لا يجوز تثبيت أو تحميل أي تطبيق أو برنامج إلا بعد الحصول على موافقة مكتوبة من مدير إدارة تقنية المعلومات.

7.3.2 يجب أن تكون جميع البرمجيات الإدارية مرخصة وموثقة في سجل التراخيص، ويُشترط توثيق تاريخ الشراء، فترة الترخيص، الجهة المزودة، وتاريخ التجديد القادم.

7.3.3 يُلزم باستخدام نظام آلي لمراقبة الامتثال البرمجي، لرصد استخدام البرمجيات غير المرخصة أو المشبوهة، على أن تُرسل تقارير الامتثال شهريًا إلى مدير الأمن السيبراني.

7.3.4 يُعد أي استخدام غير مصرح به للبرمجيات أو تثبيت من مصادر غير معتمدة مخالفة صريحة للسياسة ويُحاسب عليها الموظف وفقًا للإجراءات التأديبية.

- 7.4 الحسابات والصلاحيات:
- 7.4.1 يجب تخصيص حساب مستخدم فريد لكل موظف يتعامل مع أنظمة المعلومات الإدارية، مع ربطه مباشرة بدليل الصلاحيات المعتمد.
- 7.4.2 يُلزم بتحديث ومراجعة صلاحيات المستخدمين كل 3 أشهر بالتعاون بين الموارد البشرية وتقنية المعلومات.
- 7.4.3 يجب حذف أو تعليق صلاحيات الدخول فوراً عند انتهاء علاقة الموظف بالشركة أو تغيير مهامه، ولا يُسمح بالإبقاء على أي حساب غير نشط لأكثر من 30 يوماً دون مبرر رسمي.
- 7.5 أمن البريد الإلكتروني والإنترنت:
- 7.5.1 يُلزم باستخدام البريد الإلكتروني المؤسسي فقط لأغراض العمل الرسمي، ويُمنع استخدامه للتسجيل في خدمات خارجية غير مصرح بها.
- 7.5.2 يُراقب استخدام البريد الإلكتروني والإنترنت عبر أنظمة حماية ذكية، ويجب إعداد تقارير تحليل الأنشطة المشبوهة بشكل شهري.
- 7.5.3 يجب الإبلاغ عن أي بريد إلكتروني مشبوه أو محاولات تصيد فوراً إلى فريق الدعم الفني، ولا يُسمح للمستخدمين بفتح مرفقات من مصادر غير معروفة.
- 7.6 النسخ الاحتياطي واستعادة البيانات:
- 7.6.1 يجب تنفيذ نسخ احتياطي دوري لجميع المعلومات الإدارية الإلكترونية المخزنة على خوادم الشركة، وفق جدول زمني يومي على الأقل.
- 7.6.2 يُلزم بتخزين النسخ الاحتياطية في موقع منفصل وآمن يُراعى فيه توفر أنظمة الحماية البيئية (الحرارة، الرطوبة، الحريق).
- 7.6.3 يجب تشفير جميع النسخ الاحتياطية باستخدام خوارزميات تشفير قوية (AES-256 على الأقل)، لضمان حماية البيانات من الوصول غير المصرح به.
- 7.6.4 يجب اختبار قدرة استعادة البيانات شهرياً من النسخ الاحتياطية لضمان جاهزية النظام في حالات الطوارئ.
- 7.6.5 يُمنع استخدام وسائط خارجية محمولة (مثل USB) لتنفيذ النسخ الاحتياطي إلا في حالات الضرورة، وبعد الحصول على موافقة خطية من مشرف تقنية المعلومات.
- 7.6.6 يجب أن تشمل خطة النسخ الاحتياطي بيانات البريد الرسمي، محاضر الاجتماعات، قرارات الإدارة العليا، وقواعد البيانات الإدارية.
- 7.7 حماية البريد الإلكتروني الرسمي:
- 7.7.1 يجب استخدام البريد الإلكتروني الرسمي (dib.sa@) فقط للأغراض المهنية المتعلقة بالعمل الإداري.
- 7.7.2 يُلزم بعدم مشاركة محتوى البريد مع أطراف خارجية دون موافقة مسبقة من الجهة المالكة للمعلومة.
- 7.7.3 يُمنع استخدام البريد الإلكتروني الرسمي للتسجيل في مواقع أو خدمات غير مرتبطة بمصالح الشركة.
- 7.7.4 يجب تفعيل خاصية التحقق الثنائي (FA2) لجميع حسابات البريد الإلكتروني الإداري.
- 7.7.5 تُراجع سجلات الدخول للبريد الإلكتروني شهرياً من قبل مسؤول الأمن السيبراني، وتُوثق أي محاولة دخول مشبوهة.
- 7.8 إدارة الحوادث الأمنية المرتبطة بالمعلومات الإدارية:
- 7.8.1 يجب الإبلاغ الفوري عن أي فقد، تسريب، تعديل غير مصرح به، أو اشتباه في اختراق للمعلومات الإدارية، وذلك خلال ساعة واحدة من الاكتشاف.
- 7.8.2 يُلزم كل موظف برفع بلاغ رسمي عبر نظام إدارة الحوادث الداخلية، مع تحديد نوع الحادث، موقعه، وتوقيته.
- 7.8.3 تُعد تقارير تحليل السبب الجذري للحوادث من قبل مسؤول الأمن السيبراني بالتعاون مع الإدارة المالكة للمعلومة، ويُقدّم تقرير رسمي للإدارة التنفيذية خلال 48 ساعة.
- 7.8.4 تُحتفظ سجلات الحوادث التقنية في ملف مشفّر ضمن أرشيف الأمن السيبراني لمدة لا تقل عن 5 سنوات.
- 7.8.5 تُنفذ تمارين محاكاة نصف سنوية لاختبار جاهزية استجابة الشركة لحوادث المعلومات الإدارية.
- 7.9 التوثيق والأرشيف:
- 7.9.1 يجب على جميع الإدارات توثيق المعلومات الإدارية الصادرة والواردة باستخدام النظام الإلكتروني المعتمد لإدارة الوثائق (DMS).
- 7.9.2 يُلزم بحفظ الوثائق الإدارية المهمة مثل محاضر الاجتماعات، المراسلات الرسمية، قرارات الإدارة، وخطط العمل في مجلدات مؤرشفة بأسماء واضحة وتواريخ معتمدة.

- 7.9.3 تُحدّد فترة الاحتفاظ حسب نوع الوثيقة:
- 7.9.3.1 وثائق تنظيمية: 10 سنوات
- 7.9.3.2 مراسلات تشغيلية: 5 سنوات
- 7.9.3.3 نماذج يومية: سنتان
- 7.9.4 يُمنع إتلاف أو حذف أي وثيقة إدارية قبل انتهاء المدة المحددة لها، إلا بموافقة مكتوبة من مدير تقنية المعلومات والمدير المعني.
- 7.9.5 تُنفذ عملية إتلاف الوثائق إلكترونياً باستخدام أدوات حذف نهائي، وتوثق ضمن سجل الإتلاف الإداري.
- 7.10 التدريب والتوعية:
- 7.10.1 يجب على إدارة تقنية المعلومات، بالتعاون مع إدارة الموارد البشرية، تنفيذ برامج توعية دورية لتعريف الموظفين بمسؤولياتهم تجاه حماية المعلومات الإدارية.
- 7.10.2 يُلزم بعقد دورة توجيهية جديدة لكل موظف ينضم حديثاً إلى الشركة، تتضمن شرحاً مفصلاً حول سياسات التعامل مع الوثائق والمعلومات الإدارية.
- 7.10.3 يجب تنفيذ ورش عمل داخلية نصف سنوية تغطي المواضيع التالية على الأقل:
- 7.10.3.1 أمن المعلومات الإدارية
- 7.10.3.2 طرق تصنيف المعلومات
- 7.10.3.3 ضوابط التوثيق والحفظ
- 7.10.3.4 آلية الإبلاغ عن الحوادث
- 7.10.4 يُطلب من جميع الموظفين التوقيع على إقرار خطي بالاطلاع والالتزام بسياسة إدارة المعلومات الإدارية، ويُحفظ الإقرار ضمن ملفهم الوظيفي.
- 7.10.5 تُقاس فعالية البرامج التدريبية عبر استبيانات دورية، ويُعد تقرير سنوي لعرض نسبة الوعي ومستوى الالتزام.
- 7.11 الامتثال التنظيمي والتشريعي:
- 7.11.1 يجب أن تلتزم جميع العمليات المرتبطة بإدارة المعلومات الإدارية بالتعليمات الصادرة عن الجهات الرقابية التالية:
- 7.11.1.1 الهيئة العامة للرقابة الإدارية ومكافحة الفساد
- 7.11.1.2 هيئة التأمين السعودية
- 7.11.1.3 الهيئة الوطنية للأمن السيبراني (NCA)
- 7.11.1.4 هيئة الاتصالات والفضاء والتقنية (CST)
- 7.11.1.5 سدايا (SDAIA) في ما يخص حماية البيانات الشخصية
- 7.11.2 يُلزم بتحديث السياسة فور صدور تعليمات جديدة تؤثر على طريقة جمع أو حفظ أو تداول المعلومات الإدارية.
- 7.11.3 تُراجع مدى مطابقة الممارسات للمتطلبات التشريعية سنوياً من قبل إدارة الأمن السيبراني، وتُرفع التوصيات إلى الإدارة العليا.
- 7.11.4 يجب أن تشمل العقود مع الجهات الخارجية بنوداً واضحة حول الامتثال للأنظمة المعمول بها في المملكة العربية السعودية.
- 7.12 الربط مع مزودي الخدمات التقنية:
- 7.12.1 يُمنع استخدام أي نظام أو تطبيق خارجي لمعالجة أو تخزين المعلومات الإدارية إلا بعد اعتماده رسمياً من إدارة تقنية المعلومات.
- 7.12.2 يجب على كافة مزودي الخدمات التقنية توقيع اتفاقية مستوى خدمة (SLA) تتضمن بنوداً واضحة حول حماية البيانات، التوافر، وسرعة الاستجابة.
- 7.12.3 تُراجع عقود مزودي الخدمات سنوياً للتأكد من استمرارية الالتزام ببنود السرية والامتثال الأمني.
- 7.12.4 يُشترط أن يكون لكل مزود بوابة دعم فني نشطة، وتُتابع البلاغات عبر نظام تذاكر رسمي يُراقب من قبل تقنية المعلومات.
- 7.12.5 تُمنح صلاحيات الدخول لممثلي المزودين وفقاً لمبدأ أقل صلاحية، وتُلغى فور انتهاء التعاقد.
- 7.13 الحوكمة والمساءلة:
- 7.13.1 يجب تحديد "مالكي المعلومات الإدارية" في كل إدارة، وتوثيق مسؤولياتهم في تصنيف، مراجعة، واعتماد تداول الوثائق الصادرة عن إدارتهم.
- 7.13.2 يُلزم مالك المعلومة بإبلاغ إدارة تقنية المعلومات بأي تغيير في مستوى سرية المعلومات أو نطاق استخدامها.
- 7.13.3 يجب على مشرف تقنية المعلومات تنفيذ مراجعة ربع سنوية لسجلات الوصول والتعديلات على الوثائق الإدارية ذات الطابع الحساس.

- 7.13.4 تُعد إدارة الأمن السيبراني تقارير امتثال دورية تشمل نسب الالتزام، الثغرات المرصودة، وسلوك المستخدمين، وتُعرض على لجنة الأمن المعلوماتي.
- 7.13.5 تُطبق إجراءات محاسبية صارمة بحق كل موظف يُثبت إهماله أو تسببه في خرق هذه السياسة، وفق نظام العمل والجزاءات الداخلية.
- 7.14 خطة استمرارية الأعمال واستعادة البيانات (Business Continuity and Recovery):
- 7.14.1 يجب على إدارة تقنية المعلومات بالتنسيق مع إدارة المخاطر وضع خطة استمرارية أعمال (BCP) وخطة استعادة بيانات (DRP) تغطي جميع الأنظمة والبيانات الإدارية الحيوية.
- 7.14.2 يُلزم بتحديث ومراجعة هذه الخطة بشكل سنوي أو عند حدوث تغييرات تنظيمية أو تقنية تؤثر على استمرارية الأعمال.
- 7.14.3 يجب تنفيذ محاكاة لاختبار فعالية خطط الاستمرارية مرتين في السنة على الأقل، وتوثيق النتائج والإجراءات التصحيحية.
- 7.14.4 تُحتفظ نسخ محدثة من خطط الاستمرارية والاسترجاع في موقع إلكتروني محمي ونسخة ورقية في مكان آمن ماديًا.
- 7.15 التوعية والتدريب الأمني للموظفين:
- 7.15.1 يُلزم جميع الموظفين الذين يتعاملون مع المعلومات الإدارية بحضور تدريب سنوي حول حماية البيانات، أمن المعلومات، وسياسات الشركة ذات العلاقة.
- 7.15.2 يجب أن يشمل التدريب موضوعات: سرية المعلومات، التعامل مع الوثائق، الإبلاغ عن الحوادث، واستخدام الأنظمة.
- 7.15.3 يجب تقييم فعالية التدريب من خلال اختبار معرفي بعد كل دورة تدريبية، وتوثيق نتائج التقييم.
- 7.15.4 تُنظم إدارة تقنية المعلومات حملات توعية ربع سنوية تشمل نشرات بريدية، ملصقات داخلية، أو ورش عمل قصيرة.
- 7.16 إدارة النماذج والوثائق الرسمية:
- 7.16.1 يجب أن يتم اعتماد جميع النماذج الإدارية المستخدمة في الشركة من الإدارة التنفيذية وتحديثها حسب الحاجة التشغيلية.
- 7.16.2 تُرقم جميع النماذج برمز معرفية (Code) وتعتمد بصيغ إلكترونية داخل النظام المعتمد لإدارة الوثائق (DMS).
- 7.16.3 يُمنع استخدام أي نموذج إداري لم يتم اعتماده رسميًا، ويُحاسب أي موظف يستخدم نماذج قديمة أو غير رسمية.
- 7.16.4 تُراجع النماذج المعتمدة سنويًا لضمان مواءمتها مع التغييرات التشغيلية أو التنظيمية.
- 7.17 مراقبة الامتثال والتدقيق الدوري:
- 7.17.1 يجب على إدارة الأمن السيبراني بالتعاون مع إدارة تقنية المعلومات إجراء تدقيق ربع سنوي على مدى الالتزام بسياسة إدارة المعلومات الإدارية.
- 7.17.2 يُعد تقرير تفصيلي عن نتائج التدقيق، يشمل الثغرات والمخالفات ومقترحات التحسين، ويُرفع إلى المدير التنفيذي.
- 7.17.3 تُحفظ تقارير التدقيق في سجل الامتثال وتُراجع من قبل إدارة المخاطر والامتثال.
- 7.17.4 يُلزم كل قسم بتقديم خطة تصحيحية لأي مخالفة يتم رصدها ضمن مهلة لا تتجاوز 15 يومًا من تاريخ التقرير.
- 7.18 إنهاء العلاقة الوظيفية ونقل الموظفين:
- 7.18.1 يجب على إدارة الموارد البشرية إخطار إدارة تقنية المعلومات قبل إنهاء خدمة أي موظف أو نقله إلى قسم آخر بما لا يقل عن 3 أيام عمل.
- 7.18.2 يُلزم بإلغاء صلاحيات الوصول إلى الأنظمة والملفات الإدارية في نفس يوم الخروج الوظيفي، وتشمل الحسابات، البريد الإلكتروني، وأنظمة المستندات.
- 7.18.3 في حالة نقل الموظف إلى قسم آخر، يجب إعادة تقييم صلاحياته حسب مهامه الجديدة، وتوثيق التعديلات في سجل إدارة الوصول.
- 7.18.4 تُسجل جميع العمليات المتعلقة بإلغاء أو تعديل الصلاحيات ضمن سجل رسمي، ويُراجع هذا السجل ربع سنويًا من قبل مسؤول النظام.
- 7.19 مشاركة المعلومات مع جهات خارجية:
- 7.19.1 يُمنع مشاركة أي وثائق إدارية أو بيانات تنظيمية مع أطراف خارجية إلا بموافقة خطية من الإدارة التنفيذية أو بموجب عقد رسمي.
- 7.19.2 يجب أن تتضمن جميع العقود مع الجهات الخارجية بنودًا صريحة حول سرية المعلومات، الامتثال للأنظمة، وحقوق الشركة في التدقيق والمراجعة.
- 7.19.3 تُوثق كافة عمليات المشاركة الخارجية في سجل خاص يتضمن الجهة المستفيدة، نوع البيانات، سبب المشاركة، وتاريخ الموافقة.
- 7.19.4 يجب التأكد من أن الجهة المستلمة للمعلومات تمتلك وسائل حماية مناسبة وتوقع على نموذج تعهد بالسرية.

7.20 إدارة الوثائق الورقية:

- 7.20.1 تُحفظ الوثائق الورقية الإدارية في خزائن مؤمنة داخل مقرات الشركة وتكون مزودة بأقفال ومراقبة مرئية إن أمكن.
- 7.20.2 يُمنع إخراج الملفات الورقية الإدارية من مقر الشركة إلا بتصريح رسمي، ويجب إعادة تسليمها خلال نفس يوم العمل.
- 7.20.3 تُحدد مدة الاحتفاظ بكل نوع من أنواع الوثائق الورقية بناءً على "جدول الاحتفاظ والإتلاف" المعتمد من إدارة الامتثال.
- 7.20.4 عند انتهاء مدة الاحتفاظ، يجب إتلاف الوثائق باستخدام آلية تقطيع (Shredder) أو عبر مزود خدمة معتمد لتدمير الوثائق، مع إصدار محضر إتلاف موقع من شاهدين.

7.21 الاستخدام الشخصي وغير المتعلق بالعمل:

- 7.21.1 يُسمح بالاستخدام المحدود لشبكة الإنترنت والبريد الإلكتروني لأغراض شخصية أثناء فترات الراحة أو خارج أوقات العمل، شريطة ألا يؤثر ذلك على أداء الموظف أو أداء الشبكة أو يتعارض مع أنظمة الشركة.
- 7.21.2 يُمنع استخدام الإنترنت أو البريد الإلكتروني الشخصي لتصفح مواقع ترفيهية، ألعاب إلكترونية، أو خدمات بث مباشر أثناء ساعات العمل الرسمية.
- 7.21.3 تُسجل جميع الاستخدامات تلقائيًا، ولا تتحمل إدارة تقنية المعلومات مسؤولية التمييز بين الاستخدام المهني والشخصي، ويُحمل الموظف المسؤولية الكاملة عن أي استخدام مخالف.

7.22 حظر استخدام المدونات ووسائل التواصل الاجتماعي الشخصية:

- 7.22.1 يُمنع على الموظفين استخدام منصات النشر الإلكتروني مثل المدونات الشخصية أو وسائل التواصل الاجتماعي (Twitter، Instagram، TikTok، وغيرها) أثناء ساعات العمل أو من خلال أجهزة الشركة.
- 7.22.2 يُمنع نشر أي محتوى متعلق بالشركة أو عملها أو موظفيها على أي منصة خارجية دون تصريح رسمي.
- 7.22.3 تُعد أي مشاركة أو تعليق يحمل اسم الشركة أو يشير إليها بشكل مباشر أو غير مباشر دون تفويض، مخالفة صريحة للسياسة تستوجب التحقيق والمساءلة.

7.23 حقوق النشر والملكية الفكرية:

- 7.23.1 يُمنع تحميل أو استخدام أو نسخ أي محتوى خاضع لحقوق نشر أو ملكية فكرية تعود لطرف ثالث، دون الحصول على إذن كتابي مسبق من الجهة المالكة.
- 7.23.2 يُسمح بتحميل نسخة واحدة من المواد المحمية لغرض الاستخدام الداخلي أو البحثي فقط، مع الالتزام الصارم بشروط الترخيص.
- 7.23.3 تُحمل الشركة الموظف المسؤولية القانونية الكاملة في حال انتهاك حقوق النشر، وتحتفظ بحقها في اتخاذ إجراءات داخلية تأديبية موازية.

7.24 التعهد والاعتماد:

- 7.24.1 يُلزم كل موظف ممنوح له صلاحية استخدام الأنظمة التقنية، الإنترنت، أو البريد الإلكتروني، بالتوقيع على نموذج تعهد رسمي بالإطلاع الكامل على هذه السياسة والالتزام التام بها.
- 7.24.2 يُحتفظ بنسخة من التعهد في الملف الوظيفي للموظف لدى إدارة الموارد البشرية، وتُرسل نسخة إلكترونية إلى إدارة تقنية المعلومات للأرشفة.
- 7.24.3 يُمنع منح أي صلاحية تقنية قبل توقيع هذا التعهد واعتماده رسميًا.

7.25 التحسين المستمر ومراقبة الأداء:

- 7.25.1 تُجري إدارة تقنية المعلومات مراجعات داخلية نصف سنوية لتقييم كفاءة الأنظمة، مستوى الامتثال، والجاهزية التقنية.
- 7.25.2 تُعد تقارير تحسين تقني تتضمن التوصيات والمبادرات المقترحة، وتُرفع إلى الإدارة التنفيذية للاعتماد والتنفيذ.
- 7.25.3 يُحفز الموظفون على تقديم اقتراحات تطويرية، ويُخصص بريد داخلي أو نموذج إلكتروني لاستقبالها.

7.26 حماية البيانات الشخصية:

- 7.26.1 تلتزم الشركة بتطبيق متطلبات نظام حماية البيانات الشخصية الصادر عن سدايا، واللائحة التنفيذية ذات العلاقة.
- 7.26.2 يُمنع تخزين أو معالجة أي بيانات شخصية (مثل رقم الهوية أو رقم الجوال أو بيانات العميل) إلا ضمن أنظمة معتمدة ومحمية.
- 7.26.3 يُلزم المسؤول عن النظام بتوثيق الغرض من جمع البيانات، فترة الاحتفاظ، وأذونات المعالجة، وفقًا لمبدأ "الحد الأدنى من البيانات".
- 7.26.4 تُبلغ أي حالات خرق لبيانات شخصية إلى الهيئة المختصة خلال 72 ساعة من اكتشافها، حسب ما تنص عليه اللائحة.

7.27 إدارة الأجهزة المحمولة التابعة للشركة:

- 7.27.1 تُسلم الأجهزة المحمولة (مثل اللابتوبات، الجوالات، أو أجهزة البصمة والكاميرات) للموظفين بموجب نموذج استلام عهدة.
7.27.2 يجب تأمين الجهاز باستخدام قفل تلقائي، وبرمجيات حماية معتمدة.
7.27.3 يُمنع تثبيت برامج شخصية أو نسخ بيانات الشركة إلى وسائط خارجية دون موافقة مسبقة.
7.27.4 تُراجع الأجهزة بشكل دوري كل 6 أشهر، ويُرفع تقرير بالمخالفات أو الأعطال إلى إدارة تقنية المعلومات.

8. مسؤولية السياسة:

8.1 إدارة تقنية المعلومات:

- 8.1.1 مسؤولون عن التنسيق مع الإدارات المعنية لضمان تكامل البيانات، حماية الأنظمة، وتحديث السجلات.
8.1.2 مسؤولون عن قيادة جهود التوعية والتدريب لجميع الموظفين حول آليات استخدام الأنظمة، حماية البيانات، والإبلاغ عن الحوادث.
8.1.3 مسؤولون عن رصد الأداء والامتثال عبر مراجعات دورية، ورفع تقارير تحليلية إلى الإدارة العليا.
8.1.4 مسؤولون عن إدارة البلاغات الفنية والحوادث السيبرانية، بالتعاون مع إدارة الأمن السيبراني.
8.1.5 مسؤولون عن اعتماد الأنظمة والمزودين التقنيين الخارجيين، وضبط معايير الدخول والصيانة والدعم الفني.

8.2 قسم الأمن السيبراني:

- 8.2.1 مسؤولون عن تقييم المخاطر التقنية، إعداد تقارير الامتثال، ومراقبة النشاطات المشبوهة، ويُطلب من جميع الإدارات التشغيلية والمساندة الالتزام الكامل بتطبيق الضوابط المحددة في هذه السياسة، والتنسيق المستمر مع تقنية المعلومات لضمان حماية المعلومات الإدارية.

8.3 إدارة الالتزام والامتثال:

- 8.3.1 مسؤولون عن تقييم المخاطر التقنية، إعداد تقارير الامتثال، ومراقبة النشاطات المشبوهة، ويُطلب من جميع الإدارات التشغيلية والمساندة الالتزام الكامل بتطبيق الضوابط المحددة في هذه السياسة، والتنسيق المستمر مع تقنية المعلومات لضمان حماية المعلومات الإدارية.

8.4 إدارة الجودة والتطوير:

- 8.4.1 مسؤولون عن التأكد من تطبيق هذه السياسات من خلال التدقيق والمراجعة الدورية.

9. التعاميم والتعليمات ذات العلاقة:

- 9.1 التأكيد على الالتزام بالتعليمات الخاصة بحماية البيانات الشخصية، الصادرة عن البنك المركزي السعودي، برقم (44043873)، بتاريخ 18/12/2024 م.
9.2 أي تعاميم تخص السياسة من الجهات المشرفة.

10. حفظ السياسة:

- 10.1 تحفظ النسخة الإلكترونية الغير قابلة للنسخ من السياسة المُعتمدة على نظام الموارد البشرية ويطلع عليها الإدارات ذات العلاقة.
10.2 تحفظ النسخة الورقية من السياسة المُعتمدة في إدارة الجودة والتطوير حسب المدة النظامية المُحددة في كُتيب تقاؤم المُستندات ترحل نظامياً إلى حفظ المُستندات.

11. مخالفة السياسة:

- 11.1 يُطبق في حق المُخالف لهذه السياسة ماورد في لائحة جزاءات شركة داييموند المُعتمدة.